TP 5 - Analyse d’une application Android vulnérable

Modèle de rapport - Ubuntu + téléphone Android connecté en USB

Étudiant	Adama SANOGO
Module	IoT / Reverse engineering Android
Application analysée	InjuredAndroid

1. Objectif du TP

L'objectif est d'analyser InjuredAndroid sur Ubuntu avec un téléphone Android connecté en USB. Le TP suit trois phases : analyse statique avec JADX, analyse dynamique avec Frida, puis exploration / bypass avec Objection. Sur un téléphone non rooté, la méthode recommandée consiste à patcher l'APK avec Frida Gadget via Objection avant d'utiliser Frida en mode réseau.

2. Environnement de travail

Élément	Valeur / état attendu
OS d'analyse	Ubuntu
Cible dynamique	Téléphone Android connecté en USB
Application	InjuredAndroid.apk
Outils	adb, jadx, frida-tools, objection, apktool, aapt, jarsigner
Mode conseillé	Téléphone non rooté + APK patchée avec Frida Gadget

3. Phase 0 - Préparation du téléphone et d'Ubuntu

3.1 Activation du débogage USB sur le téléphone

- Activer Options pour les développeurs sur le téléphone.
- Activer Débogage USB.
- Brancher le téléphone en USB puis accepter la fenêtre « Autoriser le débogage USB ».
- Si nécessaire sous Ubuntu, installer android-sdk-platform-tools-common et vérifier l'accès USB.

EMPLACEMENT CAPTURE - Téléphone connecté et autorisation USB
Nom conseillé : `téléphone_connecté_et_autorisation_usb.png`

3.2 Vérification ADB

Depuis Ubuntu, vérifier que le téléphone est bien détecté.

```
adb devices
```

EMPLACEMENT CAPTURE - Résultat adb devices

```
adama@adama-virtual-machine: ~/Bureau
adama@adama-virtual-machine:~/Bureau$ adb devices
* daemon not running; starting now at tcp:5037
* daemon started successfully
List of devices attached
```

```
(tp5usb) adama@adama-virtual-machine:~/Téléchargements$ lsusb
adb devices
Bus 002 Device 005: ID 2717:ff08 Xiaomi Inc. Redmi Note 3 (ADB Interface)
Bus 002 Device 001: ID 1d6b:0002 Linux Foundation 2.0 root hub
Bus 001 Device 004: ID 0e0f:0008 VMware, Inc. Virtual Bluetooth Adapter
Bus 001 Device 003: ID 0e0f:0002 VMware, Inc. Virtual USB Hub
Bus 001 Device 002: ID 0e0f:0003 VMware, Inc. Virtual Mouse
Bus 001 Device 001: ID 1d6b:0001 Linux Foundation 1.1 root hub
List of devices attached
UOEUSSQKZD9LN76H        device
```

3.3 Vérification des outils sur Ubuntu

Vérifier la présence de Java, adb, Frida et Objection.

```
java -version
adb version
frida --version
objection version
```

EMPLACEMENT CAPTURE - Versions des outils

```
(tp5usb) adama@adama-virtual-machine:~/Bureau$ source ~/venvs/tp5usb/bin/activate
java -version
adb version
frida --version
objection version
openjdk version "11.0.30" 2026-01-20
OpenJDK Runtime Environment (build 11.0.30+7-post-Ubuntu-1ubuntu122.04)
OpenJDK 64-Bit Server VM (build 11.0.30+7-post-Ubuntu-1ubuntu122.04, mixed mode, sharing)
Android Debug Bridge version 1.0.41
Version 28.0.2-debian
Installed as /usr/lib/android-sdk/platform-tools/adb
17.9.1
objection: 1.12.4
(tp5usb) adama@adama-virtual-machine:~/Bureau$
```

3.4 Installation de InjuredAndroid sur android Xiaomi

```
ls -lh ~/Téléchargements/InjuredAndroid.apk
adb -d install -r ~/Téléchargements/InjuredAndroid.apk
adb -d shell pm list packages | grep injured
adb -d shell getprop ro.product.cpu.abi
```

EMPLACEMENT CAPTURE - InjuredAndroid

```
(tp5usb) adama@adama-virtual-machine:~/Téléchargements$ ls -lh ~/Téléchargements/InjuredAndroid.apk
adb -d install -r ~/Téléchargements/InjuredAndroid.apk
adb -d shell pm list packages | grep injured
adb -d shell getprop ro.product.cpu.abi
-rwxrw-rw- 1 adama adama 18M avril  2 16:06 /home/adama/Téléchargements/InjuredAndroid.apk
Performing Streamed Install
Success
package:b3nac.injuredandroid
arm64-v8a
(tp5usb) adama@adama-virtual-machine:~/Téléchargements$
```

4. Phase 1 - Analyse statique de l'APK

4.1 Décompilation avec JADX

Décompresser JADX, puis décompiler l'APK dans un dossier de sortie.

```
wget https://github.com/skylot/jadx/releases/download/v1.4.7/jadx-1.4.7.zip
unzip jadx-1.4.7.zip -d jadx-1.4.7
./jadx-1.4.7/bin/jadx -d injured_out/ InjuredAndroid.apk
```

EMPLACEMENT CAPTURE - Décompilation JADX

```
(tp5usb) adama@adama-virtual-machine:~/Bureau/tp5_usb$ wget https://github.com/skylot/jadx/releases/download/v1.4.7
/jadx-1.4.7.zip
unzip jadx-1.4.7.zip -d jadx-1.4.7
--2026-04-03 03:07:33--  https://github.com/skylot/jadx/releases/download/v1.4.7/jadx-1.4.7.zip
Résolution de github.com (github.com)… 140.82.121.4
Connexion à github.com (github.com)|140.82.121.4|:443… connecté.
requête HTTP transmise, en attente de la réponse… 302 Found
Emplacement : https://release-assets.githubusercontent.com/github-production-release-asset/8859474/3aad24f8-0e9e-46
5a-a813-20bfa9fb510e?sp=r&sv=2018-11-09&sr=b&spr=https&se=2026-04-03T01%3A53%3A40Z&rscd=attachment%3B+filename%3Dja
dx-1.4.7.zip&rsct=application%2Foctet-stream&skoid=96c2d410-5711-43a1-aedd-ab1947aa7ab0&sktid=398a6654-997b-47e9-b1
2b-9515b896b4de&skt=2026-04-03T00%3A53%3A15Z&ske=2026-04-03T01%3A53%3A40Z&sks=b&skv=2018-11-09&sig=l%2BZQVDiIkmqBiH
Tb0xgp8WTCV%2B%2BbzB08eduX%2F0XZ5Yw%3D&jwt=eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJpc3MiOiJnaXRodWIuY29tIiwiYXVkIjo
icmVsZWFzZS1hc3NldHMuZ2l0aHVidXNlcmNvbnRlbnQuY29tIiwia2V5Ijoia2V5MSIsImV4cCI6MTc3NTE4MDI1MywibmJmIjoxNzc1MTc4NDUzLC
JwYXRoIjoicmVsZWFzZWFzc2V0cHJvZHVjdGlvbi5ibG9iLmNvcmUud2luZG93cy5uZXQifQ.B_fKciX7ZVHMq4Jraderbrtm5J0hm85Im5mltuisbV
w&response-content-disposition=attachment%3B%20filename%3Djadx-1.4.7.zip&response-content-type=application%2Foctet-
stream [suivant]
--2026-04-03 03:07:33--  https://release-assets.githubusercontent.com/github-production-release-asset/8859474/3aad2
4f8-0e9e-465a-a813-20bfa9fb510e?sp=r&sv=2018-11-09&sr=b&spr=https&se=2026-04-03T01%3A53%3A40Z&rscd=attachment%3B+fi
lename%3Djadx-1.4.7.zip&rsct=application%2Foctet-stream&skoid=96c2d410-5711-43a1-aedd-ab1947aa7ab0&sktid=398a6654-9
97b-47e9-b12b-9515b896b4de&skt=2026-04-03T00%3A53%3A15Z&ske=2026-04-03T01%3A53%3A40Z&sks=b&skv=2018-11-09&sig=l%2BZ
QVDiIkmqBiHTb0xgp8WTCV%2B%2BbzB08eduX%2F0XZ5Yw%3D&jwt=eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJpc3MiOiJnaXRodWIuY29t
IiwiYXVkIjoicmVsZWFzZS1hc3NldHMuZ2l0aHVidXNlcmNvbnRlbnQuY29tIiwia2V5Ijoia2V5MSIsImV4cCI6MTc3NTE4MDI1MywibmJmIjoxNzc
1MTc4NDUzLCJwYXRoIjoicmVsZWFzZWFzc2V0cHJvZHVjdGlvbi5ibG9iLmNvcmUud2luZG93cy5uZXQifQ.B_fKciX7ZVHMq4Jraderbrtm5J0hm85
Im5mltuisbVw&response-content-disposition=attachment%3B%20filename%3Djadx-1.4.7.zip&response-content-type=applicati
on%2Foctet-stream
```

4.2 Lecture du AndroidManifest.xml

Repérer les activités et les composants importants.

```
grep -A3 'activity' injured_out/resources/AndroidManifest.xml
```

EMPLACEMENT CAPTURE - Manifest et activités

```
(tp5usb) adama@adama-virtual-machine:~/Bureau/tp5_usb$ grep -A3 'activity' injured_out/resources/AndroidManifest.xm
l
        <activity android:theme="@style/AppTheme.NoActionBar" android:label="@string/title_activity_flag_seventeen"
 android:name="b3nac.injuredandroid.FlagSeventeenActivity"/>
        <activity android:theme="@style/AppTheme.NoActionBar" android:label="@string/title_activity_c_s_p_bypass" a
ndroid:name="b3nac.injuredandroid.CSPBypassActivity">
            <intent-filter>
                <action android:name="android.intent.action.VIEW"/>
                <category android:name="android.intent.category.DEFAULT"/>
--
        </activity>
        <activity android:theme="@style/AppTheme.NoActionBar" android:label="@string/title_activity_assembly" andro
id:name="b3nac.injuredandroid.AssemblyActivity"/>
        <activity android:theme="@style/AppTheme" android:name="io.flutter.embedding.android.FlutterActivity" andro
id:configChanges="fontScale|layoutDirection|density|screenSize|uiMode|screenLayout|orientation|keyboardHidden|keybo
ard|locale" android:windowSoftInputMode="adjustResize" android:hardwareAccelerated="true"/>
        <activity android:theme="@style/AppTheme.NoActionBar" android:label="@string/title_activity_rce" android:na
me="b3nac.injuredandroid.RCEActivity">
            <intent-filter android:label="filter_view_flag11">
                <action android:name="android.intent.action.VIEW"/>
                <category android:name="android.intent.category.DEFAULT"/>
--
        </activity>
        <activity android:name="b3nac.injuredandroid.SettingsActivity"/>
        <activity android:theme="@style/AppTheme.NoActionBar" android:label="@string/title_activity_exported_protec
```

4.3 Recherche de secrets dans le code

Chercher des chaînes sensibles telles que password, secret, token ou api_key.

```
grep -R -n 'api_key\|password\|secret\|token' injured_out/sources/
```

EMPLACEMENT CAPTURE - Recherche de secrets

```
(tp5usb) adama@adama-virtual-machine:~/Bureau/tp5_usb$ grep -R -n 'api_key\|password\|secret\|token' injured_out/so
urces/
injured_out/sources/androidx/appcompat/view/menu/h.java:75:            attributes.token = iBinder;
injured_out/sources/androidx/appcompat/widget/a1.java:53:        layoutParams.token = view.getApplicationWindowToke
n();
injured_out/sources/b3nac/injuredandroid/i.java:271:    public static final int password_toggle = 2131230987;
injured_out/sources/b3nac/injuredandroid/R.java:573:        public static final int passwordToggleContentDescriptio
n = 0x7f0301f8;
injured_out/sources/b3nac/injuredandroid/R.java:574:        public static final int passwordToggleDrawable = 0x7f03
01f9;
injured_out/sources/b3nac/injuredandroid/R.java:575:        public static final int passwordToggleEnabled = 0x7f030
1fa;
injured_out/sources/b3nac/injuredandroid/R.java:576:        public static final int passwordToggleTint = 0x7f0301fb
;
injured_out/sources/b3nac/injuredandroid/R.java:577:        public static final int passwordToggleTintMode = 0x7f03
01fc;
injured_out/sources/b3nac/injuredandroid/R.java:1319:        public static final int res_0x7f070000_avd_hide_passwo
rd__0 = 0x7f070000;
injured_out/sources/b3nac/injuredandroid/R.java:1320:        public static final int res_0x7f070001_avd_hide_passwo
rd__1 = 0x7f070001;
injured_out/sources/b3nac/injuredandroid/R.java:1321:        public static final int res_0x7f070002_avd_hide_passwo
rd__2 = 0x7f070002;
injured_out/sources/b3nac/injuredandroid/R.java:1322:        public static final int res_0x7f070003_avd_show_passwo
rd__0 = 0x7f070003;
injured_out/sources/b3nac/injuredandroid/R.java:1323:        public static final int res_0x7f070004_avd_show_passwo
rd__1 = 0x7f070004;
injured_out/sources/b3nac/injuredandroid/R.java:1324:        public static final int res_0x7f070005_avd_show_passwo
rd__2 = 0x7f070005;
injured_out/sources/b3nac/injuredandroid/R.java:1412:        public static final int avd_hide_password = 0x7f07005d
;
injured_out/sources/b3nac/injuredandroid/R.java:1413:        public static final int avd_show_password = 0x7f07005e
;
injured_out/sources/b3nac/injuredandroid/R.java:1446:        public static final int design_password_eye = 0x7f0700
7f;
injured_out/sources/b3nac/injuredandroid/R.java:1759:        public static final int password_toggle = 0x7f08010b;
```

4.4 Recherche d'activités exportées

Identifier les activités exportées qui pourraient être appelées directement.

```
grep -B2 'exported.*true' injured_out/resources/AndroidManifest.xml
```

EMPLACEMENT CAPTURE - Activités exportées

```
(tp5usb) adama@adama-virtual-machine:~/Bureau/tp5_usb$ grep -B2 'exported.*true' injured_out/resources/AndroidManif
est.xml
        </activity>
        <activity android:name="b3nac.injuredandroid.SettingsActivity"/>
        <activity android:theme="@style/AppTheme.NoActionBar" android:label="@string/title_activity_exported_protec
ted_intent" android:name="b3nac.injuredandroid.ExportedProtectedIntent" android:exported="true"/>
        <activity android:name="b3nac.injuredandroid.QXV0aA" android:exported="true"/>
--
        <activity android:name="b3nac.injuredandroid.DisplayPostXSS"/>
        <activity android:name="b3nac.injuredandroid.FlagOneSuccess"/>
        <activity android:name="b3nac.injuredandroid.b25lActivity" android:exported="true"/>
--
        <activity android:theme="@style/AppTheme.NoActionBar" android:label="@string/title_activity_flag_three" and
roid:name="b3nac.injuredandroid.FlagThreeActivity"/>
        <activity android:theme="@style/AppTheme.NoActionBar" android:label="@string/title_activity_flag_four" andr
oid:name="b3nac.injuredandroid.FlagFourActivity"/>
        <receiver android:name="b3nac.injuredandroid.FlagFiveReceiver" android:exported="true"/>
        <activity android:theme="@style/AppTheme.NoActionBar" android:label="@string/title_activity_flag_five" andr
oid:name="b3nac.injuredandroid.FlagFiveActivity"/>
        <activity android:theme="@style/AppTheme.NoActionBar" android:label="@string/title_activity_test_broadcast_
reciever" android:name="b3nac.injuredandroid.TestBroadcastReceiver" android:exported="true"/>
        <activity android:name="b3nac.injuredandroid.ContactActivity"/>
        <activity android:theme="@android:style/Theme.Translucent.NoTitleBar" android:name="com.google.firebase.aut
h.internal.FederatedSignInActivity" android:permission="com.google.firebase.auth.api.gms.permission.LAUNCH_FEDERATE
D_SIGN_IN" android:exported="true" android:excludeFromRecents="true" android:launchMode="singleTask"/>
        <service android:name="com.google.firebase.components.ComponentDiscoveryService" android:exported="false" a
ndroid:directBootAware="true">
(tp5usb) adama@adama-virtual-machine:~/Bureau/tp5_usb$
```

4.5 Observations de la phase statique

Classes ou fichiers intéressants trouvés :
Le fichier AndroidManifest.xml met en évidence plusieurs composants sensibles, notamment b3nac.injuredandroid.ExportedProtectedIntent, b3nac.injuredandroid.QXV0aA, b3nac.injuredandroid.b25lActivity, b3nac.injuredandroid.FlagFiveReceiver et b3nac.injuredandroid.TestBroadcastReceiver. Les classes liées à Firebase et à l'authentification ressortent également dans les sources décompilées.

Secrets ou indicateurs sensibles repérés :
La recherche par mots-clés a fait ressortir plusieurs références à google_api_key, google_crash_reporting_api_key, ainsi que différents éléments liés aux tokens d'authentification Firebase (access_token, refresh_token, id_token, oauth_token_secret). Tous les résultats ne correspondent pas à des secrets exploitables directement, mais ils révèlent la présence de mécanismes d'authentification et de configuration cloud intégrés à l'application.

Activités exportées identifiées :
Les composants exportés les plus notables sont ExportedProtectedIntent, QXV0aA, b25lActivity, FlagFiveReceiver et TestBroadcastReceiver. La présence de ces activités et récepteurs exportés montre que plusieurs points d'entrée de l'application sont accessibles depuis l'extérieur.

Commentaires personnels sur la surface d'attaque :
La surface d'attaque de l'application est relativement large. La présence de plusieurs composants exportés, combinée à des références à des clés ou tokens dans les sources, augmente les possibilités d'abus ou de contournement. Même si certains résultats proviennent de bibliothèques tierces, l'analyse montre que l'application expose suffisamment d'indices pour orienter une attaque ou un reverse engineering plus poussé.

5. Phase 2 - Préparation de la partie dynamique

Sur un téléphone Android non rooté, la méthode la plus fiable est de patcher l'APK avec Frida Gadget via Objection. Cette section décrit cette méthode, puis la connexion Frida en mode réseau.

5.1 Installation de l'APK d'origine et vérifications

```
adb -d shell pm list packages | grep injured
adb -d shell pidof b3nac.injuredandroid
adb -d forward tcp:27042 tcp:27042
adb -d shell getprop ro.product.cpu.abi
```

EMPLACEMENT CAPTURE - APK installée et architecture du téléphone

```
adama@adama-virtual-machine:~/Bureau$ adb -d shell pm list packages | grep injured
adb -d shell pidof b3nac.injuredandroid
adb -d forward tcp:27042 tcp:27042
adb -d shell getprop ro.product.cpu.abi
package:b3nac.injuredandroid
9918
arm64-v8a
```

5.2 Vérification des dépendances pour Objection

Avant le patch, vérifier la présence de apktool, aapt et jarsigner.

```
apktool
which jarsigner
aapt version
```

EMPLACEMENT CAPTURE - Dépendances Objection

Capture attendue : sorties montrant apktool, jarsigner et aapt disponibles.

Nom conseillé : `dépendances_objection.png`

5.3 Patch de l'APK avec Frida Gadget

Patcher l'APK pour injecter Frida Gadget. Si l'architecture n'est pas détectée automatiquement, la forcer.

```
objection patchapk --source InjuredAndroid.apk
# ou
objection patchapk --source InjuredAndroid.apk --architecture arm64-v8a
```

EMPLACEMENT CAPTURE - Patch APK réussi

```
(tp5usb) adama@adama-virtual-machine:~/Téléchargements$ cd ~/Bureau/tp5_usb
source ~/venvs/tp5usb/bin/activate
objection patchapk --source InjuredAndroid.apk --architecture arm64-v8a
Using latest Github gadget version: 17.9.1
Patcher will be using Gadget version: 17.9.1
Detected apktool version as: 3.0.1
Running apktool empty-framework-dir...
Apktool 3.0.1 - a tool for reengineering Android apk files
with smali 3.0.9-dev and baksmali 3.0.9-dev
Copyright 2010 Ryszard Wiśniewski <brut.alll@gmail.com>
Copyright 2010 Connor Tumbleson <connor.tumbleson@gmail.com>

General options:
 -q,--quiet     Suppress normal output.
 -v,--verbose   Increase output verbosity.

apktool d|decode [options] <apk-file>
 -a,--all-src              Decode all sources in the apk (includes unknown dex files).
 -f,--force                Force delete destination directory.
 -j,--jobs <num>           Set the number of jobs to execute in parallel to <num>.
 -l,--lib <package:file>   Use shared library <package> located in <file>.
                           Can be specified multiple times.
 -o,--output <dir>         Output decoded files to <dir>. (default: apk.out)
 -p,--frame-path <dir>     Use framework files located in <dir>.
 -r,--no-res               Do not decode resources.
 -s,--no-src               Do not decode sources.
 -t,--frame-tag <tag>      Use framework files tagged with <tag>.

apktool b|build [options] <apk-dir>
 -f,--force                Skip changes detection and build all files.
 -j,--jobs <num>           Set the number of jobs to execute in parallel to <num>.
 -l,--lib <package:file>   Use shared library <package> located in <file>.
                           Can be specified multiple times.
 -o,--output <file>        Output the built apk to <file>. (default: dist/name.apk)
 -p,--frame-path <dir>     Use framework files located in <dir>.
```

```
For additional info, see: https://apktool.org
For smali/baksmali info, see: https://github.com/google/smali
Unpacking InjuredAndroid.apk
App already has android.permission.INTERNET
Target class not specified, searching for launchable activity instead...
Reading smali from: /tmp/tmp5jxpfasi.apktemp/smali/b3nac/injuredandroid/MainActivity.smali
Injecting loadLibrary call at line: 10
Attempting to fix the constructors .locals count
Current locals value is 0, updating to 1:
Writing patched smali back to: /tmp/tmp5jxpfasi.apktemp/smali/b3nac/injuredandroid/MainActivity.smali
Copying Frida gadget to libs path...
Rebuilding the APK with the frida-gadget loaded...
Built new APK with injected loadLibrary and frida-gadget
Performing zipalign
Zipalign completed
Signing new APK.
Signed the new APK
Copying final apk from /tmp/tmp5jxpfasi.apktemp.aligned.objection.apk to InjuredAndroid.objection.apk in current directo
ry...
Cleaning up temp files...
(tp5usb) adama@adama-virtual-machine:~/Bureau/tp5_usb$ ls -lh *.apk
-rwxrw-r-- 1 adama adama 18M avril  3 03:07 InjuredAndroid.apk
-rw-rw-r-- 1 adama adama 28M avril  3 15:26 InjuredAndroid.objection.apk
(tp5usb) adama@adama-virtual-machine:~/Bureau/tp5_usb$
```

5.4 Désinstallation de l'APK d'origine et installation de l'APK patchée

```
adb -d uninstall b3nac.injuredandroid
adb -d install -r ~/Bureau/tp5_usb/InjuredAndroid.objection.apk
```

EMPLACEMENT CAPTURE - Installation APK patchée

```
(tp5usb) adama@adama-virtual-machine:~/Bureau/tp5_usb$ adb -d uninstall b3nac.injuredandroid
Success
```

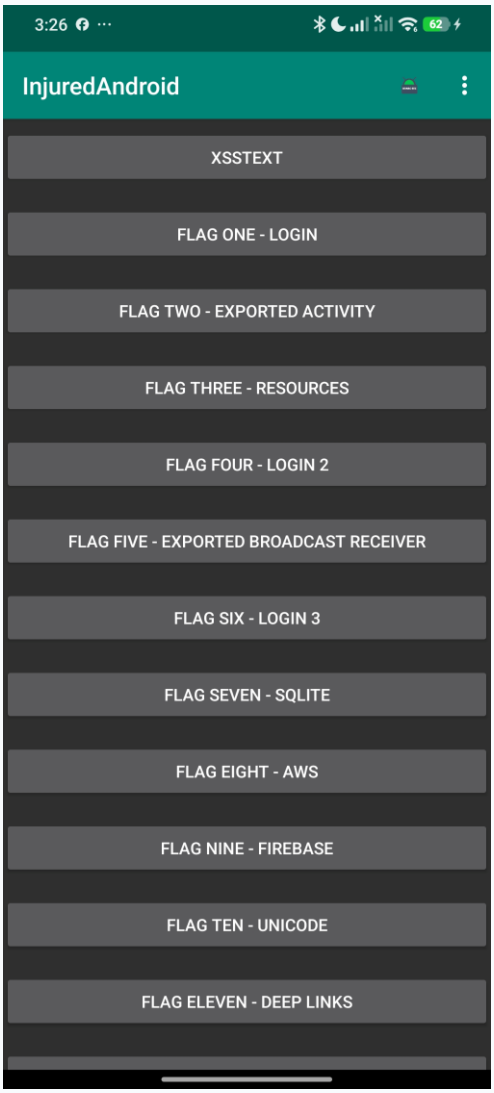
```
(tp5usb) adama@adama-virtual-machine:~/Bureau/tp5_usb$ adb devices
adb -d install -r ~/Bureau/tp5_usb/InjuredAndroid.objection.apk
List of devices attached
UOEUSSQKZD9LN76H        device

Performing Streamed Install
Success
(tp5usb) adama@adama-virtual-machine:~/Bureau/tp5_usb$
```

5.5 Lancement de l'application patchée

Ouvrir l'application sur le téléphone. Il est normal que l'application puisse sembler figée ou en attente si le Gadget attend une connexion.

EMPLACEMENT CAPTURE - Application patchée ouverte

```
(tp5usb) adama@adama-virtual-machine:~/Bureau/tp5_usb$ adb -d shell monkey -p b3nac.injuredandroid -c android.intent.cat
egory.LAUNCHER 1
  bash arg: -p
  bash arg: b3nac.injuredandroid
  bash arg: -c
  bash arg: android.intent.category.LAUNCHER
  bash arg: 1
args: [-p, b3nac.injuredandroid, -c, android.intent.category.LAUNCHER, 1]
 arg: "-p"
 arg: "b3nac.injuredandroid"
 arg: "-c"
 arg: "android.intent.category.LAUNCHER"
 arg: "1"
data="b3nac.injuredandroid"
data="android.intent.category.LAUNCHER"
Events injected: 1
## Network stats: elapsed time=87ms (0ms mobile, 0ms wifi, 87ms not connected)
(tp5usb) adama@adama-virtual-machine:~/Bureau/tp5_usb$
```



5.6 Mise en place du port forwarding ADB

```
adb -d forward tcp:27042 tcp:27042
adb forward --list
```

EMPLACEMENT CAPTURE - Port forwarding Gadget

```
(tp5usb) adama@adama-virtual-machine:~/Bureau/tp5_usb$ adb -d shell pidof b3nac.injuredandroid
24742
(tp5usb) adama@adama-virtual-machine:~/Bureau/tp5_usb$ adb -d forward tcp:27042 tcp:27042
adb forward --list
27042
UOEUSSQKZD9LN76H tcp:27042 tcp:27042
```

5.7 Vérification de la connexion Frida en mode réseau

```
frida-ps -H 127.0.0.1:27042
```

EMPLACEMENT CAPTURE - Frida-ps sur le Gadget

```
(tp5usb) adama@adama-virtual-machine:~/Bureau/tp5_usb$ frida-ps -H 127.0.0.1:27042
  PID  Name
-----  ------
24742  Gadget
(tp5usb) adama@adama-virtual-machine:~/Bureau/tp5_usb$
```

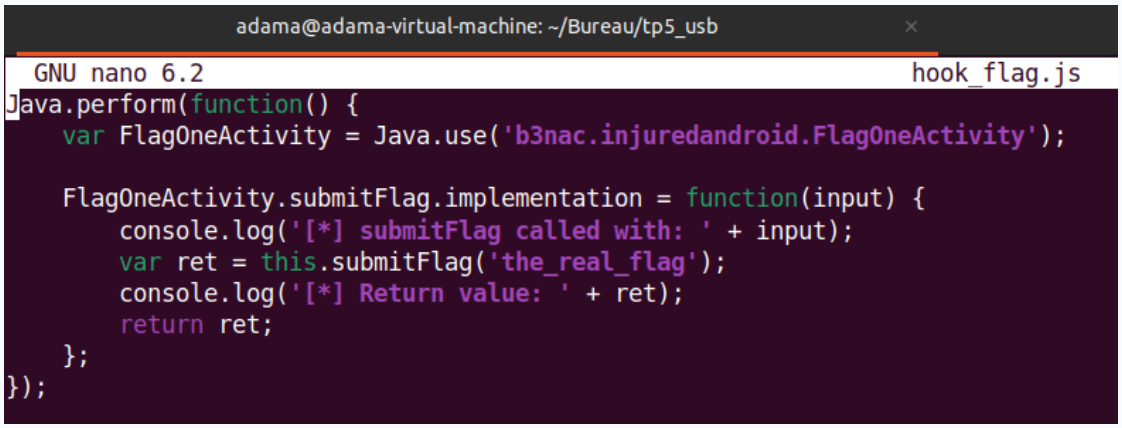
6. Phase 3 - Hook Frida

6.1 Création du script hook_flag.js

Créer le fichier hook_flag.js avec le contenu suivant :

```
Java.perform(function() {
    var FlagOneActivity = Java.use('b3nac.injuredandroid.FlagOneActivity');

    FlagOneActivity.submitFlag.implementation = function(input) {
        console.log('[*] submitFlag called with: ' + input);
        var ret = this.submitFlag('the_real_flag');
        console.log('[*] Return value: ' + ret);
        return ret;
    };
});
```

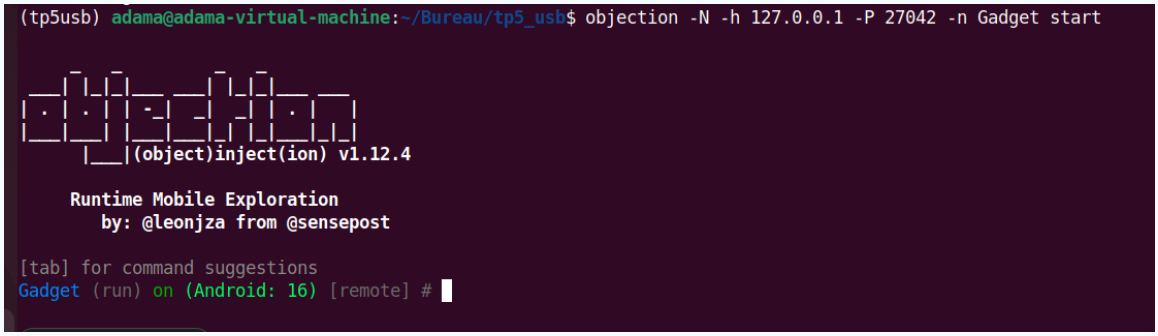
EMPLACEMENT CAPTURE - Fichier hook_flag.js



6.2 Exécution du hook via le Gadget et frida

```
objection -N -h 127.0.0.1 -P 27042 -n Gadget start
```

EMPLACEMENT CAPTURE - Exécution du hook Frida



```
adama@adama-virtual-machine:~/Bureau/tp5_usb$ frida -H 127.0.0.1:27042 -n Gadget -l ~/Bureau/tp5_usb/hook_flag.js
     ____
    / _  |   Frida 17.9.1 - A world-class dynamic instrumentation toolkit
   | (_| |
    > _  |   Commands:
   /_/ |_|       help      -> Displays the help system
   . . . .       object?   -> Display information about 'object'
   . . . .       exit/quit -> Exit
   . . . .
   . . . .   More info at https://frida.re/docs/home/
   . . . .
   . . . .   Connected to 127.0.0.1:27042 (id=socket@127.0.0.1:27042)

[Remote::Gadget ]-> [*] FlagOneLoginActivity.submitFlag(View) called
```

6.3 Résultat observé

- Connexion Frida au Gadget : Oui
- Hook exécuté : Oui
- Effet observé dans l'application : .....
- Erreur éventuelle : .....

7. Phase 4 - Exploration avec Frida

Lorsque la connexion réseau au Frida fonctionne, je tente une session Objection.

```
objection -N -h 127.0.0.1 -P 27042 -n InjuredAndroid start
```

EMPLACEMENT CAPTURE - Connexion Objection

```
(tp5usb) adama@adama-virtual-machine:~/Bureau/tp5_usb$ frida -H 127.0.0.1:27042 -n Gadget -l ~/Bureau/tp5_usb/hook_flag.js
     ____
    / _  |   Frida 17.9.1 - A world-class dynamic instrumentation toolkit
   | (_| |
    > _  |   Commands:
   /_/ |_|       help      -> Displays the help system
   . . . .       object?   -> Display information about 'object'
   . . . .       exit/quit -> Exit
   . . . .
   . . . .   More info at https://frida.re/docs/home/
   . . . .
   . . . .   Connected to 127.0.0.1:27042 (id=socket@127.0.0.1:27042)

[Remote::Gadget ]->
```

7.1 Commandes Objection à tester

```
android root disable
android sslpinning disable
file ls /data/data/b3nac.injuredandroid/
android preferences get
android hooking list activities
android intent launch_activity b3nac.injuredandroid.FlagEightLogInActivity
```

L’exploration du répertoire privé de l’application a été réalisée avec Frida. Les dossiers cache, code_cache, shared_prefs et app_sslcache ont été identifiés. La présence d’un fichier XML dans shared_prefs montre que l’application stocke des données de configuration ou de session localement.

EMPLACEMENT CAPTURE - Résultats des commandes Objection

```
adama@adama-virtual-machine:~/Bureau/tp5_usb$ frida -H 127.0.0.1:27042 -n Gadget -l ~/Bureau/tp5_usb/list_files.js
     ____
    / _  |   Frida 17.9.1 - A world-class dynamic instrumentation toolkit
   | (_| |
    > _  |   Commands:
   /_/ |_|       help      -> Displays the help system
   . . . .       object?   -> Display information about 'object'
   . . . .       exit/quit -> Exit
   . . . .
   . . . .   More info at https://frida.re/docs/home/
   . . . .
   . . . .   Connected to 127.0.0.1:27042 (id=socket@127.0.0.1:27042)
Attaching...
[*] dataDir = /data/user/0/b3nac.injuredandroid
/data/user/0/b3nac.injuredandroid
  /data/user/0/b3nac.injuredandroid/cache
    /data/user/0/b3nac.injuredandroid/cache/oat_primary
      /data/user/0/b3nac.injuredandroid/cache/oat_primary/arm64
  /data/user/0/b3nac.injuredandroid/code_cache
  /data/user/0/b3nac.injuredandroid/shared_prefs
    /data/user/0/b3nac.injuredandroid/shared_prefs/com.google.firebase.auth.api.Store.W0RFRkFVTFRd+MTo0MzA5NDMwMDYzMTY6YW5kcm9pZDpkOTdkY
jU3ZTExZTQyYTFhMDM3MjQ5.xml
  /data/user/0/b3nac.injuredandroid/app_sslcache
[Remote::Gadget ]->
```

```
adama@adama-virtual-machine:~/Bureau/tp5_usb$ frida -H 127.0.0.1:27042 -n Gadget -l ~/Bureau/tp5_usb/read_prefs.js
     ____
    / _  |   Frida 17.9.1 - A world-class dynamic instrumentation toolkit
   | (_| |
    > _  |   Commands:
   /_/ |_|       help      -> Displays the help system
   . . . .       object?   -> Display information about 'object'
   . . . .       exit/quit -> Exit
   . . . .
   . . . .   More info at https://frida.re/docs/home/
   . . . .
   . . . .   Connected to 127.0.0.1:27042 (id=socket@127.0.0.1:27042)
Attaching...
[*] Package: b3nac.injuredandroid
[*] Default SharedPreferences:
[*] shared_prefs dir: /data/user/0/b3nac.injuredandroid/shared_prefs
  prefs file: com.google.firebase.auth.api.Store.W0RFRkFVTFRd+MTo0MzA5NDMwMDYzMTY6YW5kcm9pZDpkOTdkYjU3ZTExZTQyYTFhMDM3MjQ5.xml
[Remote::Gadget ]->
```


```
adama@adama-virtual-machine:~/Bureau/tp5_usb$ frida -H 127.0.0.1:27042 -n Gadget -l ~/Bureau/tp5_usb/read_prefs.js
     ____
    / _  |   Frida 17.9.1 - A world-class dynamic instrumentation toolkit
   | (_| |
    > _  |   Commands:
   /_/ |_|       help      -> Displays the help system
   . . . .       object?   -> Display information about 'object'
   . . . .       exit/quit -> Exit
   . . . .
   . . . .   More info at https://frida.re/docs/home/
   . . . .
   . . . .   Connected to 127.0.0.1:27042 (id=socket@127.0.0.1:27042)
Attaching...
[*] Package: b3nac.injuredandroid
[*] Default SharedPreferences:
[*] shared_prefs dir: /data/user/0/b3nac.injuredandroid/shared_prefs
  prefs file: com.google.firebase.auth.api.Store.W0RFRkFVTFRd+MTo0MzA5NDMwMDYzMTY6YW5kcm9pZDpkOTdkYjU3ZTExZTQyYTFhMDM3MjQ5.xml
[Remote::Gadget ]->
```

```
adama@adama-virtual-machine:~/Bureau/tp5_usb$ frida -H 127.0.0.1:27042 -n Gadget -l ~/Bureau/tp5_usb/read_prefs.js
grep -o 'android:name="[^"]*"' ~/Bureau/tp5_usb/injured_out/resources/AndroidManifest.xml | cut -d'"' -f2
adb -d shell am start -n b3nac.injuredandroid/b3nac.injuredandroid.FlagEightLoginActivity

     ____
    / _  |   Frida 17.9.1 - A world-class dynamic instrumentation toolkit
   | (_| |
    > _  |   Commands:
   /_/ |_|       help      -> Displays the help system
   . . . .       object?   -> Display information about 'object'
   . . . .       exit/quit -> Exit
   . . . .
   . . . .   More info at https://frida.re/docs/home/
   . . . .
   . . . .   Connected to 127.0.0.1:27042 (id=socket@127.0.0.1:27042)
Attaching...
[*] Package: b3nac.injuredandroid
[*] Default SharedPreferences:
[*] shared_prefs dir: /data/user/0/b3nac.injuredandroid/shared_prefs
  prefs file: com.google.firebase.auth.api.Store.W0RFRkFVTFRd+MTc0MzA5NDMwMDYzMTY6YW5kcm9pZDpkOTdkYjU3ZTExZTQyYTFhMDM3MjQ5.xml
[Remote::Gadget ]->
```

8. Résultat pour la liste des activités

La liste des activités a été récupérée à partir du AndroidManifest.xml. Parmi les activités identifiées figurent notamment FlagOneLoginActivity, FlagEightLoginActivity, FlagSevenSqliteActivity, ExportedProtectedIntent, QXV0aA et b25lActivity.

```
adama@adama-virtual-machine:~/Bureau/tp5_usb$ grep -o 'android:name="[^"]*"' ~/Bureau/tp5_usb/injured_out/resources/AndroidManifest.xm
| cut -d'"' -f2
adb -d shell am start -n b3nac.injuredandroid/b3nac.injuredandroid.FlagEightLoginActivity
android.permission.ACCESS_NETWORK_STATE
android.permission.INTERNET
android.permission.WRITE_EXTERNAL_STORAGE
android.permission.READ_PHONE_STATE
android.permission.READ_EXTERNAL_STORAGE
b3nac.injuredandroid.FlagSeventeenActivity
b3nac.injuredandroid.CSPBypassActivity
android.intent.action.VIEW
android.intent.category.DEFAULT
android.intent.category.BROWSABLE
b3nac.injuredandroid.AssemblyActivity
io.flutter.embedding.android.FlutterActivity
b3nac.injuredandroid.RCEActivity
android.intent.action.VIEW
android.intent.category.DEFAULT
android.intent.category.BROWSABLE
b3nac.injuredandroid.SettingsActivity
b3nac.injuredandroid.ExportedProtectedIntent
b3nac.injuredandroid.QXV0aA
b3nac.injuredandroid.FlagTwelveProtectedActivity
b3nac.injuredandroid.DeepLinkActivity
android.intent.action.VIEW
android.intent.category.DEFAULT
android.intent.category.BROWSABLE
android.intent.action.VIEW
android.intent.category.DEFAULT
android.intent.category.BROWSABLE
b3nac.injuredandroid.FlagTenUnicodeActivity
b3nac.injuredandroid.FlagOneLoginActivity
b3nac.injuredandroid.FlagNineFirebaseActivity
b3nac.injuredandroid.FlagEightLoginActivity
b3nac.injuredandroid.FlagSevenSqliteActivity
b3nac.injuredandroid.FlagsOverview
b3nac.injuredandroid.FlagSixLoginActivity
b3nac.injuredandroid.MainActivity
android.intent.action.MAIN
android.intent.category.LAUNCHER
b3nac.injuredandroid.XSSTextActivity
b3nac.injuredandroid.DisplayPostXSS
b3nac.injuredandroid.FlagOneSuccess
b3nac.injuredandroid.b25lActivity
b3nac.injuredandroid.FlagTwoActivity
b3nac.injuredandroid.FlagThreeActivity
b3nac.injuredandroid.FlagFourActivity
```

- installation de l'APK originale
- analyse statique avec JADX
- identification de composants exportés
- repérage d'éléments sensibles
- patch de l'APK avec Objection

- installation de l'APK patchée
- connexion Frida via Gadget
- hook Frida réussi sur FlagOneLoginActivity.submitFlag(View)
- exploration du dossier privé de l'application
- lecture des shared_prefs
- liste des activités
- tentative de lancement direct d'une activité non exportée, avec résultat de sécurité clair

9. Analyse de sécurité

Cette partie doit synthétiser les enseignements du TP : visibilité de la logique applicative après décompilation, présence éventuelle de secrets codés en dur, activités exportées, limites d'un contrôle purement côté client, et difficultés concrètes rencontrées lors de l'instrumentation dynamique sur un téléphone non rooté.

10. Conclusion

Ce TP a permis de mettre en œuvre une analyse statique et dynamique complète d'une application Android vulnérable, InjuredAndroid.
La phase statique a permis d'identifier plusieurs composants intéressants, notamment des activités exportées et des références à des éléments sensibles liés à Firebase et à l'authentification.
La phase dynamique a ensuite été réalisée avec Frida et une APK patchée avec Frida Gadget, ce qui a permis d'instrumenter l'application sur un téléphone Android connecté en USB. Le hook de FlagOneLoginActivity.submitFlag(View) a bien fonctionné, ce qui valide l'interception dynamique d'une méthode critique.
L'exploration de l'application a également permis d'identifier son répertoire privé, son dossier shared_prefs ainsi qu'un fichier XML de préférences lié à Firebase Auth.
Enfin, le lancement direct de FlagEightLoginActivity a échoué avec une SecurityException, montrant que cette activité n'est pas exportée et qu'elle ne peut pas être appelée directement depuis l'extérieur.
Globalement, le TP a permis de démontrer l'intérêt combiné de l'analyse statique, de l'instrumentation dynamique et de l'exploration applicative pour comprendre la surface d'attaque d'une application Android.

Annexe - Checklist rapide

Étape	Commande / action	Capture à ajouter
Détection USB	`adb devices`	Oui
Installation APK	`adb -d install -r InjuredAndroid.apk`	Oui
ABI du téléphone	`adb -d shell getprop ro.product.cpu.abi`	Oui
Décompilation	`jadx -d injured_out/ InjuredAndroid.apk`	Oui
Manifest	`grep -A3 'activity' ...`	Oui
Secrets	`grep -R -n 'api_key|password|secret|token' ...`	Oui
Patch APK	`objection patchapk --source ...`	Oui
APK patchée installée	`adb -d install -r InjuredAndroid.objection.apk`	Oui
Forwarding Gadget	`adb -d forward tcp:27042 tcp:27042`	Oui
Frida réseau	`frida-ps -H 127.0.0.1:27042`	Oui
Hook Frida	`frida -H 127.0.0.1:27042 -n InjuredAndroid -l hook_flag.js`	Oui
Objection	`objection -N -h 127.0.0.1 -P 27042 -n InjuredAndroid start`	Oui